

III.4 Security concerns

In order to create a functional website, there are several security concerns you must address:

- Any password stored in your database, if applicable, must be **hashed**.
- Your website must be protected against **SQL injections/XSS** attacks.
- If you have a backend or any other features, it is mandatory to enable an HTTPS connection for all aspects (use wss instead of ws for example).
- You must implement validation mechanisms for forms and any user input, either on the base page if no backend is used, or on the server side if a backend is employed.
- Regardless of whether you choose to implement the JWT Security module with 2FA, it's essential to prioritize the security of your website. For instance, if you choose to create an API, ensure your routes are protected. Even if you decide not to use JWT tokens, securing the site remains critical.



Please make sure you use a strong password hashing algorithm



For obvious security reasons, any credentials, API keys, env variables etc., must be saved locally in a `.env` file and ignored by git. Publicly stored credentials will cause your project to fail.

IV.1 Overview

- Web

- **Major module:** Use a framework to build the backend.
- **Minor module:** Use a framework or a toolkit to build the frontend.
- **Minor module:** Use a database for the backend.
- **Major module:** Store the score of a tournament in the Blockchain.

- User Management

- **Major module:** Standard user management, authentication, users across tournaments.
- **Major module:** Implementing a remote authentication.

Gameplay and user experience

- **Major module:** Remote players
- **Major module:** Multiplayer (more than 2 players in the same game).
- **Major module:** Add another game with user history and matchmaking.
- **Minor module:** Game customization options.
- **Major module:** Live chat.

- AI-Algo

- **Major module:** Introduce an AI opponent.
- **Minor module:** User and game stats dashboards

- Cybersecurity

- **Major module:** Implement WAF/ModSecurity with a hardened configuration and HashiCorp Vault for secrets management.
- **Minor module:** GDPR compliance options with user anonymization, local data management, and Account Deletion.
- **Major module:** Implement Two-Factor Authentication (2FA) and JWT.

- Devops

- **Major module:** Infrastructure setup for log management.
- **Minor module:** Monitoring system.
- **Major module:** Designing the backend as microservices.

IV.6 Cybersecurity

These cybersecurity modules are designed to enhance the security posture of the project. The major module focuses on robust protection through Web Application Firewall (WAF) and ModSecurity configurations, as well as HashiCorp Vault for secure secrets management. The minor modules complement this effort by adding features for GDPR compliance, user data anonymization, account deletion, Two-Factor authentication (2FA), and JSON Web Tokens (JWT), collectively ensuring the project's commitment to data protection, privacy, and authentication security.

- **Major module:** Implement WAF/ModSecurity with Hardened Configuration and HashiCorp Vault for Secrets Management.

The objective of this major module is to enhance the security infrastructure of the project by implementing several key components. Key features and goals include:

- Configure and deploy a Web Application Firewall (WAF) and ModSecurity with a strict and secure configuration to protect against web-based attacks.
- Integrate HashiCorp Vault to securely manage and store sensitive information, such as API keys, credentials, and environment variables, ensuring that these secrets are properly encrypted and isolated.

This major module aims to bolster the project's security infrastructure by implementing robust security measures, including WAF/ModSecurity for web application protection and HashiCorp Vault for secrets management to ensure a safe and secure environment.

- **Minor module:** GDPR compliance options with user anonymization, local data management, and account deletion.

The goal of this minor module is to introduce GDPR compliance options that allow users to exercise their data privacy rights. Key features and objectives include:

- Implement GDPR-compliant features that enable users to request anonymization of their personal data, ensuring that their identity and sensitive information are protected.
- Provide tools for users to manage their local data, including the ability to view, edit, or delete their personal information stored within the system.
- Offer a streamlined process for users to request the permanent deletion of their accounts, including all associated data, ensuring compliance with data protection regulations.
- Maintain clear and transparent communication with users regarding their data privacy rights, with easily accessible options to exercise these rights.

This minor module aims to enhance user privacy and data protection by offering GDPR compliance options that empower users to control their personal information and exercise their data privacy rights within the system.

If you are not familiar with the General Data Protection Regulation (GDPR), it

is essential to understand its principles and implications, especially regarding user data management and privacy. The GDPR is a regulation that aims to protect the personal data and privacy of individuals within the European Union (EU) and the European Economic Area (EEA). It sets out strict rules and guidelines for organizations on how they should handle and process personal data.

To gain a better understanding of the GDPR and its requirements, it is strongly recommended to visit the official website of the European Commission on data protection¹. This website provides comprehensive information about the GDPR, including its principles, objectives, and user rights. It also offers additional resources to delve deeper into the topic and ensure compliance with the regulation.

If you are unfamiliar with the GDPR, please take the time to visit the provided link and familiarize yourself with the regulations before proceeding with this project.

- **Major module:** Implement Two-Factor Authentication (2FA) and JWT.

The goal of this major module is to enhance security and user authentication by introducing Two-Factor Authentication (2FA) and utilizing JSON Web Tokens (JWT). Key features and objectives include:

- Implement Two-Factor Authentication (2FA) as an additional layer of security for user accounts, requiring users to provide a secondary verification method, such as a one-time code, in addition to their password.
- Utilize JSON Web Tokens (JWT) as a secure method for authentication and authorization, ensuring that user sessions and access to resources are managed securely.
- Provide a user-friendly setup process for enabling 2FA, with options for SMS codes, authenticator apps, or email-based verification.
- Ensure that JWT tokens are issued and validated securely to prevent unauthorized access to user accounts and sensitive data.

This major module aims to strengthen user account security by offering Two-Factor Authentication (2FA) and enhancing authentication and authorization through the use of JSON Web Tokens (JWT).

¹https://commission.europa.eu/law/law-topic/data-protection/data-protection-eu_en